คู่มือผู้ดูแลระบบ

สำหรับ Admin (Administrator Manual)

ระบบนำส่งผู้ป่วย · PT Medical System

เวอร์ชัน 5.8.0 — 21 เมษายน 2569

สารบัญ

1. บทบาทและสิทธิ์ (Roles & Permissions)

2. เข้าหน้า Admin Settings

3. General · ข้อมูลองค์กรและ Branding

4. Services · GPS, OCR, Integrations

5. Security · Sessions และ Public Share

6. Analytics · Statistics, Activity Log, Overview

7. Monitor Dashboard

8. GPS Tracking (มุมมอง Admin)

9. การแก้ไขปัญหา (Troubleshooting)

10. แนวทางปฏิบัติด้านความปลอดภัย (Security Best Practices)

1. บทบาทและสิทธิ์ (Roles & Permissions)

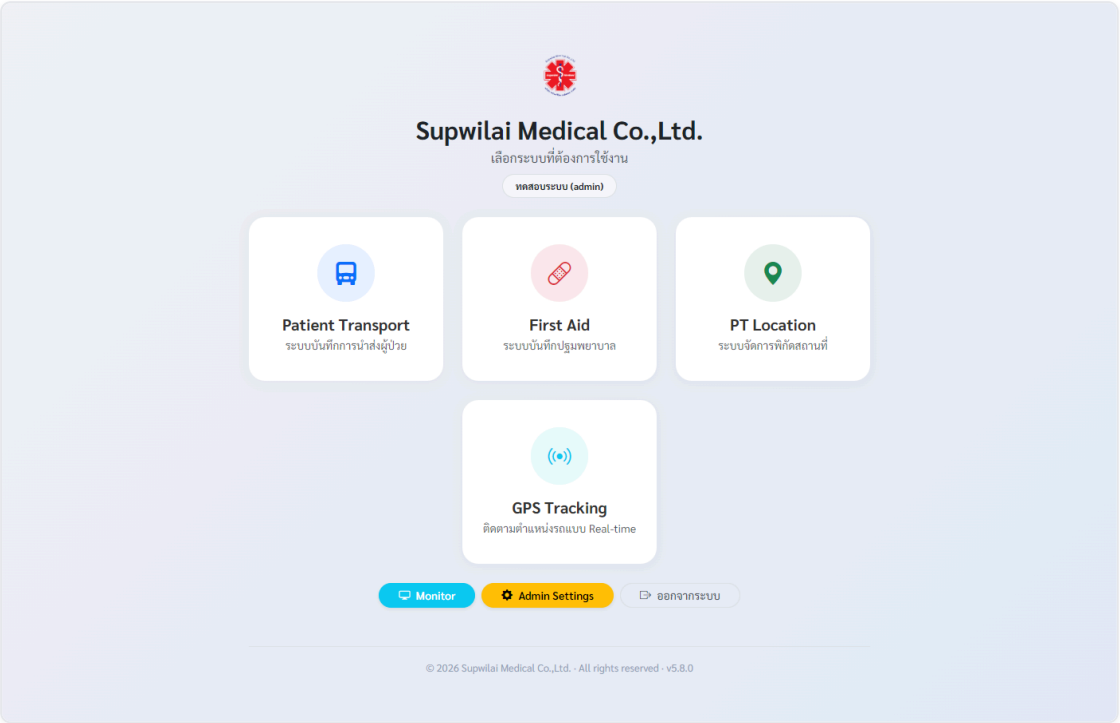
ระบบแบ่งสิทธิ์หลักเป็น 2 ระดับ:

Role	สิทธิ์
Employee (ผู้ใช้ทั่วไป)	เข้าถึง 4 โมดูล: Transport, First Aid, Location, GPS (view) — บันทึก/แก้ไขข้อมูลได้ แต่ไม่เห็นหน้า Settings/Monitor
Admin	ทุกอย่างของ Employee + เข้า Admin Settings + Monitor Dashboard + จัดการ GPS Share Links + ดู Activity Log

📘 **หมายเหตุ:** Role มาจากระบบ HR (Google Apps Script Auth) โดยเก็บที่ตาราง users field `role` — หากต้องเปลี่ยน Role ของใคร ต้องแก้ที่ฐานข้อมูลหรือแผงจัดการ HR

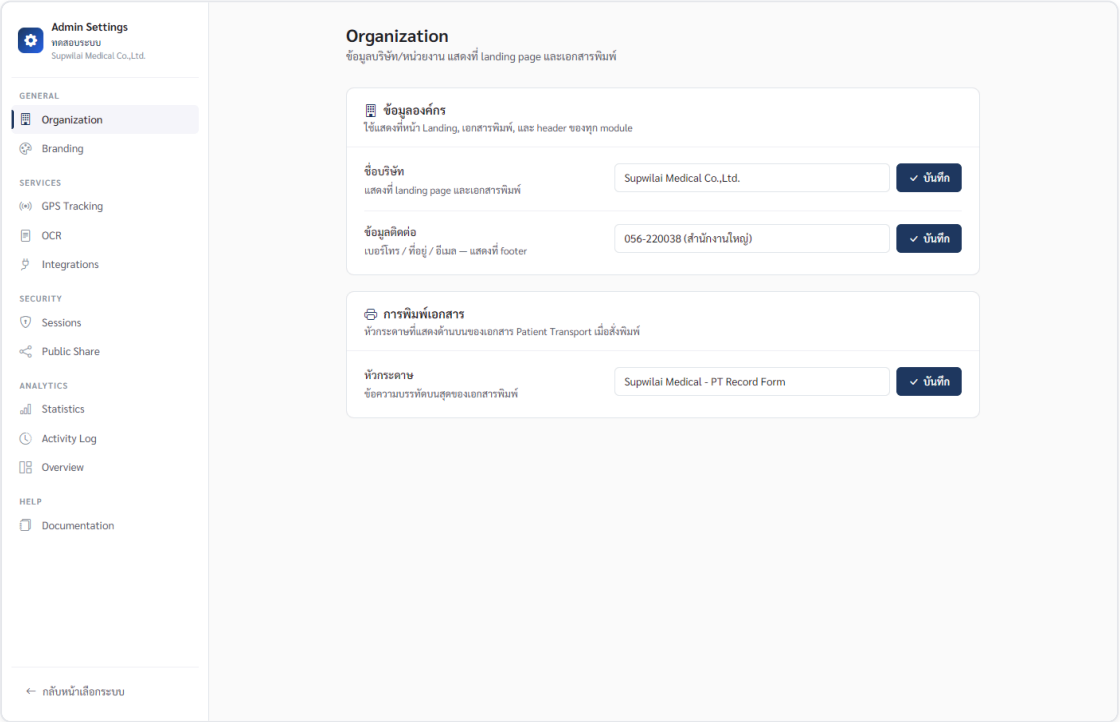
2. เข้าหน้า Admin Settings

หลัง Login ด้วยบัญชีที่มี Role = admin หน้า Landing จะแสดงปุ่มเพิ่มเติม **Monitor** และ **Admin Settings**



Landing ของ Admin — เห็นปุ่ม Monitor และ Admin Settings เพิ่มเติม

กดปุ่ม ⚙ **Admin Settings** เพื่อเข้าแผง



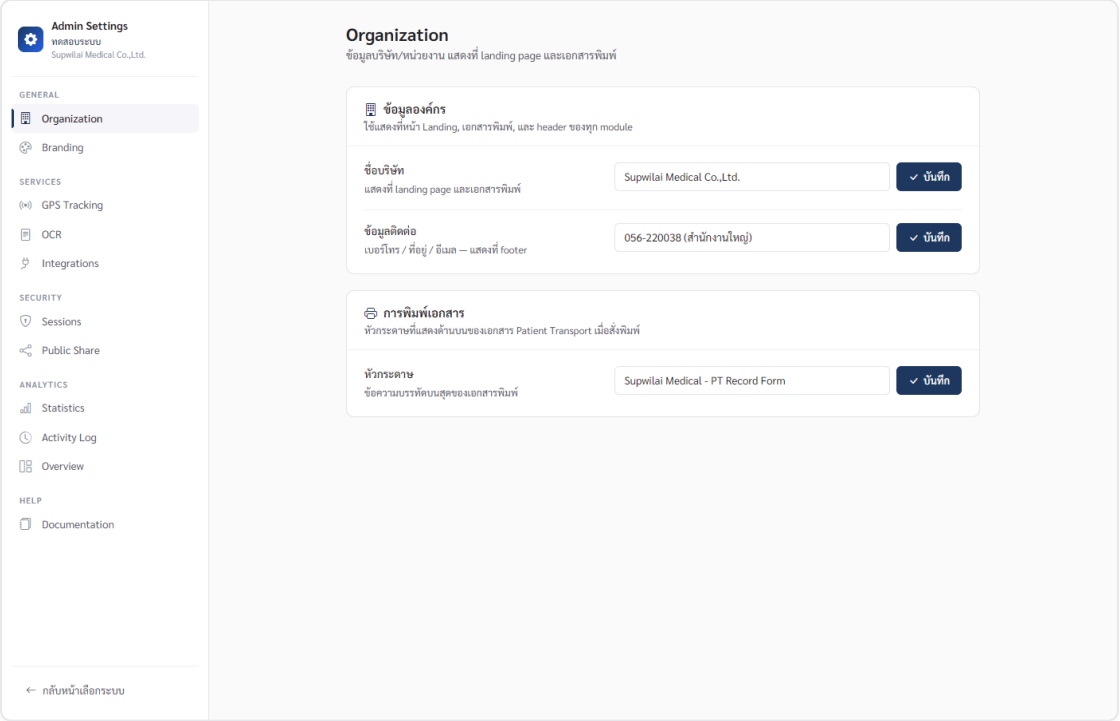
หน้า Admin Settings แท็บ Organization — โครงสร้าง Sidebar ด้านซ้าย

โครงสร้าง Sidebar

กลุ่ม	เมนู	หน้าที่
GENERAL	Organization	ข้อมูลบริษัท/หน่วยงาน ใช้แสดงที่ Landing + เอกสารพิมพ์
	Branding	โลโก้ สีธีม favicon
SERVICES	GPS Tracking	ตั้งค่า Proxy URL, Synology endpoints, refresh rate
	OCR	ตั้งค่า OCR service สำหรับ scan เอกสาร
	Integrations	Cloudinary, Google Places API, Supabase
SECURITY	Sessions	ดู session ที่ active — บังคับ logout ได้
	Public Share	จัดการ Share Token สำหรับเผยแพร่สาธารณะ
ANALYTICS	Statistics	สถิติรายเดือน/รายปี
	Activity Log	บันทึกการใช้งานของผู้ใช้ทั้งหมด
	Overview	ภาพรวมจำนวนข้อมูลในระบบ
HELP	Documentation	คู่มือภายใน เอกสารทางเทคนิค

3. General · ข้อมูลองค์กรและ Branding

3.1 Organization



Organization · ข้อมูลบริษัท/หน่วยงาน

- **ชื่อบริษัท** — แสดงที่หน้า Landing และหัวเอกสารพิมพ์
- **ข้อมูลติดต่อ** — เบอร์โทร / ที่อยู่ / อีเมล แสดงที่ footer
- **หัวกระดาษ (Print Header)** — ข้อความบรรทัดบนสุดของเอกสาร PT Record Form

> 💡 **Tip:** กด **บันทึก** หลังแก้ไขทุกครั้ง — ระบบไม่มี auto-save

3.2 Branding

ตั้งค่า:

- โลโก้บริษัท (Logo) — อัพโหลดเป็น PNG/SVG แนะนำสัดส่วน 1:1
- Favicon — ไอคอนบน tab เบราว์เซอร์
- สี Primary — สีเฮดเดอร์ ปุ่มหลัก
- สี Accent — ปุ่มรอง / highlight

4. Services · GPS, OCR, Integrations

4.1 GPS Tracking Settings

ตั้งค่า endpoint สำหรับดึงตำแหน่งรถจากระบบ GPS ภายนอก:

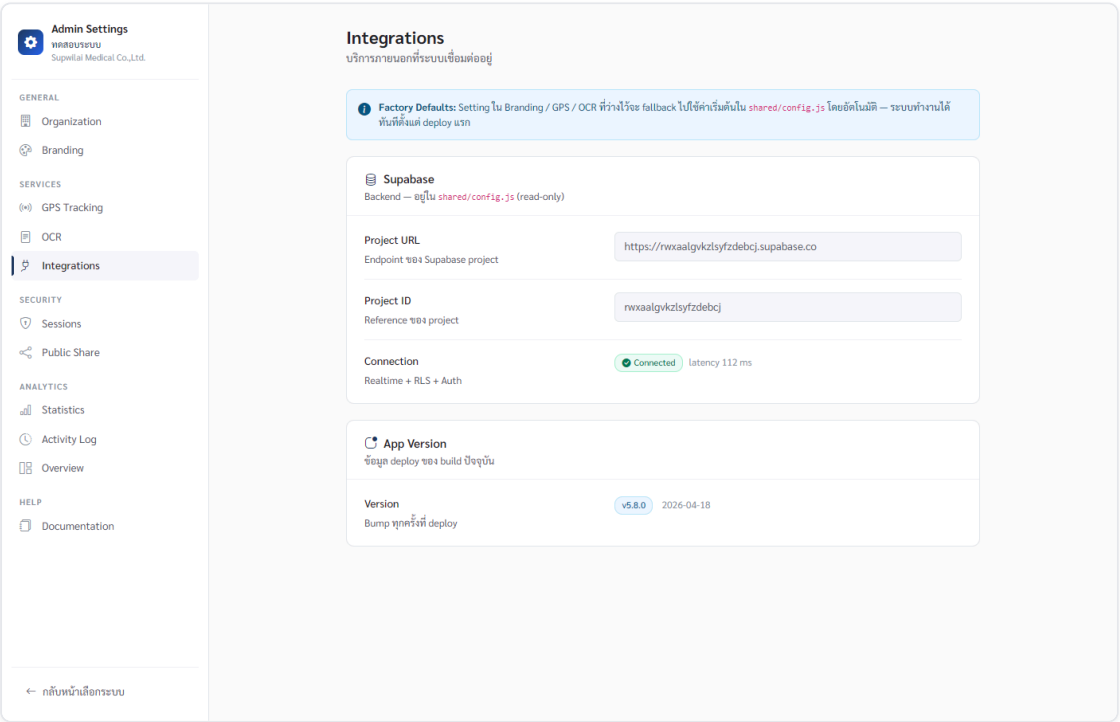
- **Proxy URL** — Render proxy ที่ทำหน้า CORS bridge (เช่น `https://xxx.onrender.com`)
- **Synology Endpoint** — สำรองกรณี Proxy ล่ม เรียก NAS ภายในตรง
- **Refresh rate** — ความถี่ดึงข้อมูล (แนะนำ 5-10 วินาที)

> ⚠️ **ข้อควรระวัง:** อย่าใส่ `Cache-Control` header ในการเรียก GPS endpoint — จะ trigger CORS preflight (OPTIONS) ที่ Render block

4.2 OCR

ตั้ง endpoint สำหรับ OCR scan เอกสาร (เช่น บัตรประชาชน) ในโมดูล Transport

4.3 Integrations



Integrations · Cloudinary, Places, Supabase

- **Cloudinary Cloud Name + Upload Preset** — อัพรูปในทุกโมดูล
- **Google Places API Key** — "ค้นหาใกล้รถ" ใน GPS module
- **Supabase URL + anon key** — ฐานข้อมูล (แก้ที่ config.js เท่านั้น)

⚠️ **ข้อควรระวัง:** Cloudinary Upload Preset ต้องเป็นแบบ **Signed** — ป้องกันการ abuse quota
เปิดที่ Cloudinary Dashboard → Upload Presets

5. Security · Sessions และ Public Share

5.1 Sessions

ดูรายการ session ที่ active ในปัจจุบัน พร้อมข้อมูล:

- ผู้ใช้, วันที่ login, IP address, User Agent
- ปุ่ม **Force Logout** — เลิก session ของผู้ใช้รายนั้น (ใช้เมื่อสงสัยว่าอุปกรณ์สูญหาย)
- ปุ่ม **Force Logout All** — บังคับออกทั้งระบบ (ใช้เมื่อ deploy สำคัญ หรือเปลี่ยน policy)

5.2 Public Share

จัดการ Share Token ที่ผู้ใช้สร้างจากหน้า Transport หรือ GPS

- ดูรายการ token ทั้งหมด + วันหมดอายุ
- **Revoke** token ที่สงสัยว่าหลุดไปยังผู้ไม่เกี่ยวข้อง
- ตั้งค่า default TTL (Time To Live) ของ token ใหม่

6. Analytics · Statistics, Activity Log, Overview

6.1 Statistics

กราฟ + ตารางสรุป:

- จำนวนเคส Transport / First Aid / Location แยกรายเดือน
- สัดส่วน BLS / ALS
- Top 10 รพ. ต้นทาง-ปลายทาง
- กราฟแนวโน้มย้อนหลัง 12 เดือน

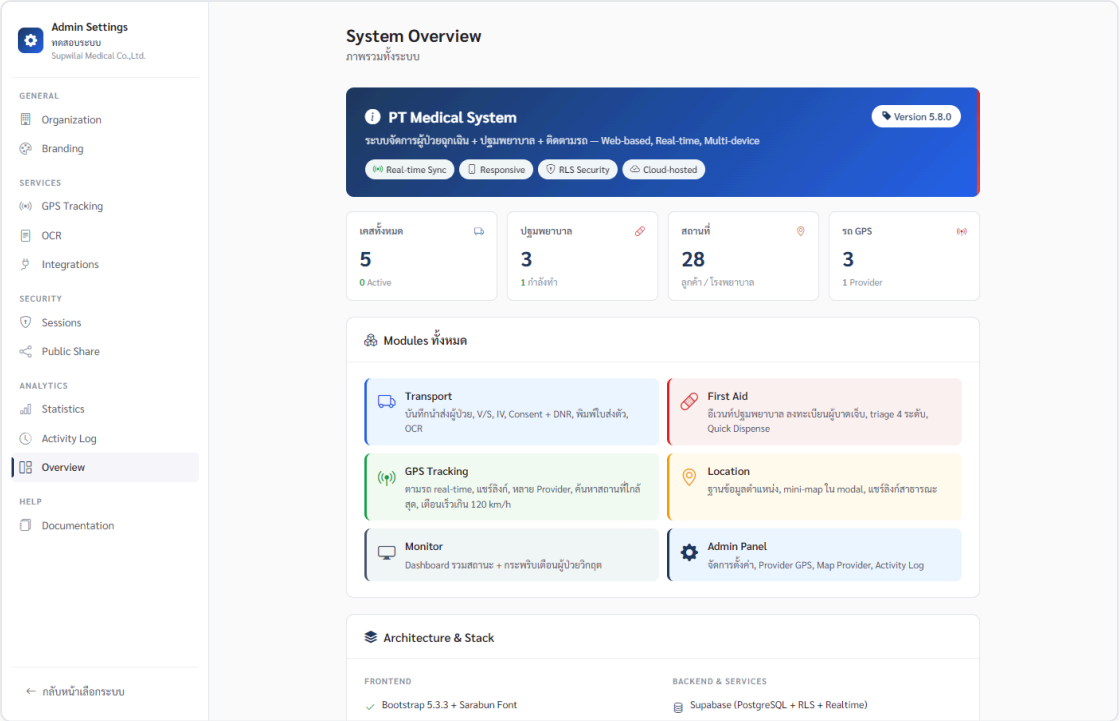
6.2 Activity Log

บันทึกการกระทำของผู้ใช้ทุกคน:

- Login / Logout
- สร้าง / แก้ไข / ลบ เคส/Event/ผู้ป่วย
- เปลี่ยนตั้งค่า Admin (ใครแก้อะไร เมื่อไร)

> 💡 **Tip:** ใช้ค้นหาได้ด้วย username, action type, date range — เหมาะสำหรับตรวจสอบปัญหาย้อนหลัง

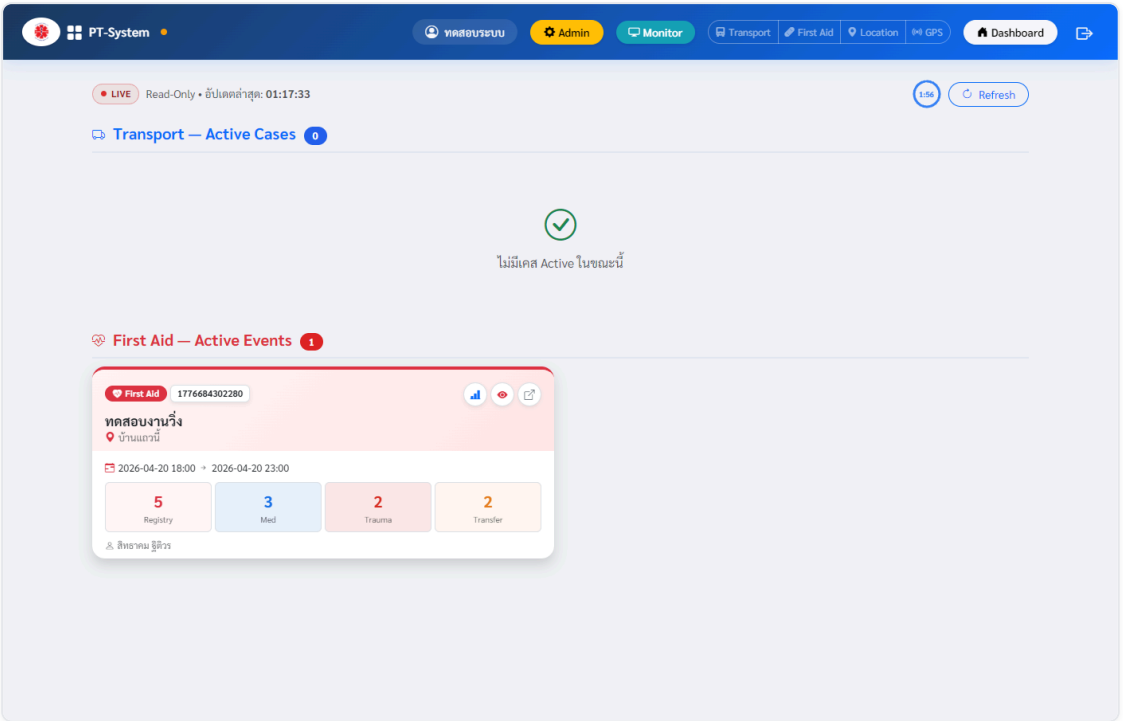
6.3 Overview



System Overview · จำนวนข้อมูลรวม

ภาพรวมจำนวนข้อมูลในระบบทั้งหมด: เคส, ผู้ป่วย, Event, สถานที่, ผู้ใช้ — ใช้เช็คสุขภาพของระบบ

7. Monitor Dashboard

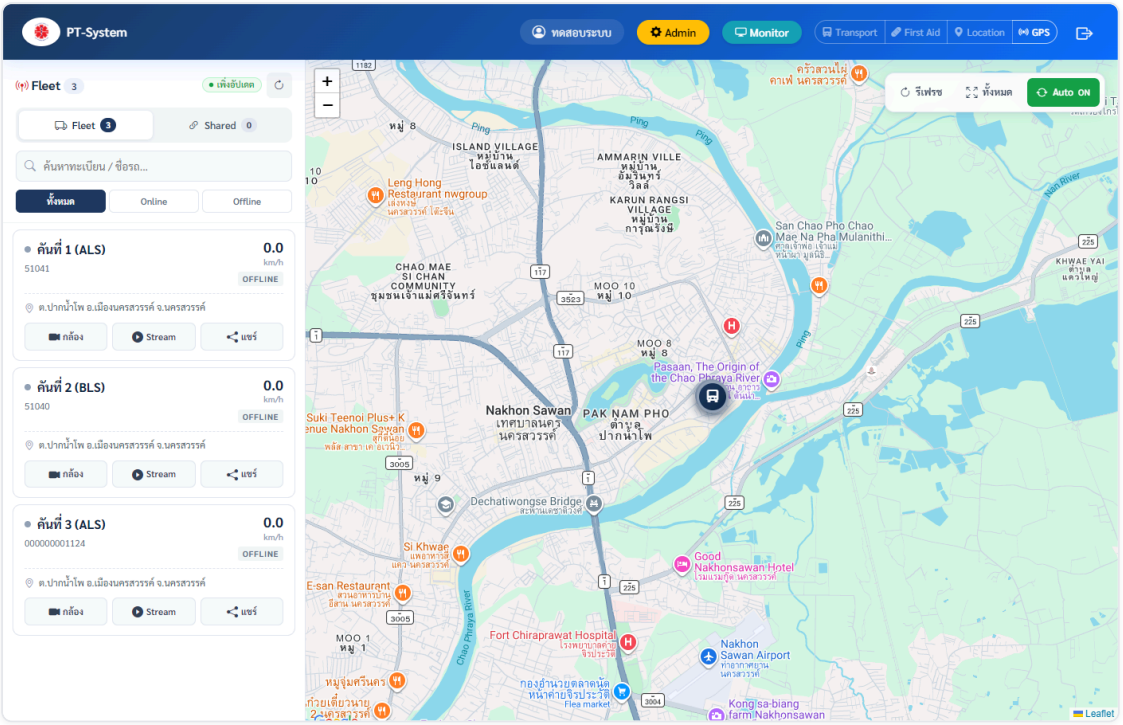


Monitor Dashboard · Live view

Dashboard รวมที่แสดงข้อมูลสำคัญแบบ Real-time เหมาะสำหรับวางบน TV/จอใหญ่ที่ศูนย์ปฏิบัติการ

- จำนวนเคสวันนี้ แยกตามสถานะ (In Progress / Done)
- Live feed เคสล่าสุด 10 รายการ
- Event First Aid ที่ Active
- ตำแหน่งรถ Real-time (ย่อ)
- แจ้งเตือนเมื่อมีเคสใหม่/Consent ใหม่

8. GPS Tracking (มุมมอง Admin)



GPS Tracking · มุมมอง Admin เห็นทั้ง Fleet และ Shared Links

ต่างจากผู้ใช้ทั่วไป Admin จะเห็นแท็บเพิ่มเติม **Shared Links**:

- **Fleet** — รายการรถของทีม (เหมือนผู้ใช้)
- **Shared Links** — จัดการ Token แชร์ GPS ให้บุคคลภายนอก ดู/สร้าง/ยกเลิก/ตั้งวันหมดอายุ

9. การแก้ไขปัญหา (Troubleshooting)

9.1 Realtime ไม่ทำงาน (จุดส้ม/แดง)

1. เปิด Supabase Dashboard → Database → Replication
2. ตรวจสอบว่าตารางทั้งหมด (cases, fa_events, fa_registry, loc_customers, transport_consents) อยู่ใน publication `supabase_realtime`
3. หากหาย รัน SQL: `ALTER PUBLICATION supabase_realtime ADD TABLE <table>;`
4. ตรวจ RLS policies มี `anon_select_*` ที่ `USING (true)`
5. Hard reload เบราว์เซอร์ (Ctrl+Shift+R)

9.2 CORS Error ที่ GPS Proxy

ถ้า Console แสดง `"Request header field cache-control is not allowed"`:

- แปลว่าโค้ดส่ง `Cache-Control` request header ไปที่ Render → Render block เพราะไม่อยู่ใน CORS allowlist
- Fix: ลบ `Cache-Control` / `Pragma` header ใน `shared/gps-providers.js` — ใช้ `cache: 'no-store'` + query-string cache-buster แทน

9.3 Cloudinary Upload Fail

- ตรวจ Upload Preset ที่ Cloudinary Dashboard ว่ายังมีอยู่ + ตั้งเป็น Unsigned หรือ Signed ตรงกับโค้ด
- เช็ค Cloud Name ใน Integrations settings
- ไฟล์ใหญ่เกิน 10MB → ย่อก่อน

9.4 ผู้ใช้ล็อกอินไม่ได้

- ตรวจสอบที่ระบบ HR ว่า user ยัง active อยู่
- ลอง force-logout session เก่าที่อาจค้าง
- ตรวจ GAS_AUTH_API_URL ยังเข้าถึงได้ (HTTP 200)

9.5 Service Worker ค้างที่เวอร์ชันเก่า

ผู้ใช้เห็นโค้ดเก่า ทั้งที่ Deploy ใหม่แล้ว:

1. Bump `CACHE_NAME` ใน `sw.js` (เช่น v11 → v12)
2. Push code
3. ให้ผู้ใช้ปิด-เปิด tab หรือ Hard reload

10. แนวทางปฏิบัติด้านความปลอดภัย (Security Best Practices)

10.1 การจัดการ Role

- ให้ Role = admin เฉพาะบุคคลที่จำเป็น (หลักการ Principle of Least Privilege)
- ทบทวนรายชื่อ admin ทุก 6 เดือน
- เมื่อพนักงานลาออก ให้ disable user ที่ HR ทันที (session ระบบจะหลุดภายใน 24 ชม.)

10.2 Sessions

- หากสงสัยว่าอุปกรณ์ของ user สูญหาย → Force Logout ทันทีที่หน้า Sessions
- ก่อนปรับ config หรือ deploy ใหญ่ → Force Logout All แล้วให้ทุกคน login ใหม่

10.3 Share Tokens

- Token ที่ไม่ได้ใช้ควร revoke
- ตั้ง TTL เริ่มต้นไม่เกิน 7 วัน — บังคับสร้างใหม่หากต้องใช้ต่อ
- อย่าส่ง token ผ่านช่องทางสาธารณะ (Facebook public post)

10.4 RLS & Database

> ⚠️ **ข้อควรระวัง:** ปัจจุบันระบบใช้ RLS แบบ `USING (true)` สำหรับ anon role — นี่หมายความว่าผู้รู้ URL สามารถเรียก Supabase ตรงได้ แนะนำให้ติดตามงาน migration RLS ให้เข้มขึ้น (ดู issue tracker)

10.5 Admin Panel Bypass

ปัจจุบันการเช็ค role อยู่ฝั่ง client (localStorage) — ผู้ใช้ที่รู้เทคนิค DevTools อาจ bypass เข้า UI admin ได้ แต่ไม่สามารถแก้ข้อมูลได้ถ้า backend มี RLS ที่ดี (ดูข้อ 10.4)

10.6 Backup

- Supabase มี Daily Backup ในตัว — ตรวจสอบที่ Supabase Dashboard → Database → Backups
- แนะนำให้ export ข้อมูลสำคัญเป็น CSV รายเดือนเก็บที่ Google Drive แยก

© 2026 PT Medical System — Administrator Manual v5.8.0